Harden Active Directory Certificate Services as Tier 0: ESC1–ESC16, NTLM relay and strong mapping

An expert hardening programme for Active Directory Certificate Services: why the CA is Tier 0, inventory and assessment with Locksmith, Certipy and Defender for Identity, fixing vulnerable templates (ESC1–ESC4, ESC9, ESC13, ESC15), CA flags and permissions (ESC6, ESC7, ESC11, ESC16), NTLM relay to Web Enrollment (ESC8), strong certificate mapping under KB5014754, Tier 0 operation and backup, auditing and detection, incident response, troubleshooting and rollback.

9 phases | 32 steps | Tick each item when its "done when" criterion is true

Phase 1 Why AD CS is Tier 0: the attack paths and the scope of this programme about 1 day

- [ ] **1.1 Classify every enterprise CA and its admins as Tier 0**
  Enterprise CAs, their hosts, their backups, their HSMs and every account with CA or template rights are listed as Tier 0 assets in the access model
- [ ] **1.2 Know the ESC families you are hardening against**
  The project team can map each finding from phase 2 to one of four groups: template issues, CA issues, relay issues and mapping issues
- [ ] **1.3 Agree scope, owners and a change window per change type**
  Each CA, template and enrollment endpoint has a named owner, and the change board has approved separate windows for template changes, CA flag changes (need a CertSvc restart) and IIS changes

Phase 2 Inventory and assess: CAs, NTAuth, templates and endpoints about 2–4 days

- [ ] **2.1 Inventory CAs, NTAuth and enrollment endpoints**
  You have a list of every enterprise CA, every CA certificate in NTAuth, every published template per CA and every HTTP(S) enrollment endpoint (certsrv, CES, CEP)
- [ ] **2.2 Run a defensive scanner: Locksmith in read-only mode**
  Locksmith has run in Mode 2 (issues to CSV) or Mode 3 (issues and example fixes to CSV) from a Tier 0 admin host, and the CSV is stored with the project evidence
- [ ] **2.3 Confirm with an attacker's view: Certipy, with written authorisation**
  An authorised tester has run `certipy find` with `-vulnerable` from a normal domain user account, and every finding is mapped to Locksmith and Secure Score results
- [ ] **2.4 Turn on Defender for Identity posture assessments for AD CS**
  A Defender for Identity sensor runs on every server with the Certification Authority role service, and the certificate recommendations appear in Secure Score

Phase 3 Fix certificate templates: ESC1–ESC4, ESC9, ESC13 and ESC15 about 1–3 weeks

- [ ] **3.1 ESC1: remove requester-supplied subjects from authentication templates**
  No published template combines 'Supply in the request' with an authentication EKU and enrollment for broad groups, unless manager approval or authorised signatures are required
- [ ] **3.2 ESC2 and ESC3: no Any Purpose, no unrestricted enrollment agents**
  No template enrollable by unprivileged users has the Any Purpose EKU or no EKU, and Certificate Request Agent templates are restricted to named enrollment agents with CA-side restrictions
- [ ] **3.3 ESC4: lock down template ACLs and owners**
  Only Tier 0 PKI admins have Write, Write Owner, Write DACL or Full Control on template objects, and no template is owned by a normal user or a broad group
- [ ] **3.4 ESC9, ESC13 and ESC15: SID extension, issuance policies and V1 templates**
  No authentication template has the no-security-extension flag, issuance-policy OIDs linked to groups are reviewed, and every CA has the November 2024 update for CVE-2024-49019
- [ ] **3.5 Retire unused templates the safe way: audit, then unpublish**
  Every published template has an owner and recent issuance, or it has been unpublished after a 30-day observation period

Phase 4 Fix CA settings and permissions: ESC6, ESC7, ESC11 and ESC16 about 2–5 days

- [ ] **4.1 ESC6: turn off EDITF_ATTRIBUTESUBJECTALTNAME2**
  `certutil -getreg policy\EditFlags` on every CA does not list `EDITF_ATTRIBUTESUBJECTALTNAME2`
- [ ] **4.2 ESC7: remove Manage CA and Manage Certificates from unprivileged principals**
  On every CA, Manage CA and Manage Certificates are held only by Tier 0 PKI groups, and the CA console Security tab matches the documented design
- [ ] **4.3 ESC11: require packet privacy on the RPC enrollment interface**
  `certutil -getreg CA\InterfaceFlags` shows `IF_ENFORCEENCRYPTICERTREQUEST` on every CA
- [ ] **4.4 ESC16: make sure the CA issues the SID security extension**
  `certutil -getreg policy\DisableExtensionList` on every CA does not contain `1.3.6.1.4.1.311.25.2`, and every CA has at least the May 2022 updates

Phase 5 Stop NTLM relay to AD CS: ESC8, Extended Protection and coercion about 3–7 days

- [ ] **5.1 Remove Web Enrollment where nobody needs it**
  Web Enrollment (`/certsrv`) is uninstalled on every CA where no documented process depends on it
- [ ] **5.2 Protect remaining endpoints: HTTPS only, Extended Protection Required, Kerberos only**
  Every remaining Web Enrollment and CES endpoint has Require SSL, Extended Protection set to Required (CES web.config `extendedProtectionPolicy` = `Always`), and Windows authentication without NTLM where possible
- [ ] **5.3 Restrict NTLM on CA servers and reduce coercion**
  CA servers deny incoming NTLM (with documented exceptions), domain controllers cannot reach arbitrary hosts over SMB/HTTP outbound, and SMB/LDAP signing is enforced

Phase 6 Strong certificate mapping on domain controllers (KB5014754, ESC10, ESC14) about 1–2 weeks

- [ ] **6.1 Confirm Full Enforcement and clear the KDC events**
  No domain controller has logged Kdcsvc event 39, 40 or 41 in the last 30 days, and none still carries a `StrongCertificateBindingEnforcement` workaround
- [ ] **6.2 ESC14: use only strong formats in altSecurityIdentities**
  Every `altSecurityIdentities` value in the domain uses X509IssuerSerialNumber, X509SKI or X509SHA1PublicKey, and write access to the attribute is limited
- [ ] **6.3 ESC10: keep Schannel on strong mapping methods**
  `CertificateMappingMethods` under `HKLM\System\CurrentControlSet\Control\SecurityProviders\Schannel` is absent or `0x18` on domain controllers

Phase 7 Operate the PKI as Tier 0: admins, hosts, keys and backup about 1–2 weeks

- [ ] **7.1 Restrict who can log on to CA servers**
  Interactive and RDP logon to CA servers is limited to the Tier 0 PKI group via GPO, from privileged access workstations, and no service or monitoring agent runs with a lower-tier account that has admin rights
- [ ] **7.2 Protect the CA private key**
  The decision on HSM or software key protection is documented; exported keys and backups are encrypted, stored offline or in a Tier 0 vault, and access is logged
- [ ] **7.3 Back up and rehearse a restore**
  A scheduled backup of the CA database and key exists, the password is in a Tier 0 vault, and a restore to an isolated server has been tested within the last 12 months

Phase 8 Audit and detect: CA auditing, Defender for Identity and hunting about 2–4 days, then ongoing

- [ ] **8.1 Enable Certification Services auditing on every CA**
  Audit Certification Services is set to Success and Failure by GPO on CA servers, and `certutil -getreg CA\AuditFilter` returns 127
- [ ] **8.2 Use Defender for Identity and Defender for Endpoint AD CS detections**
  The SOC has a runbook for the AD CS alert family, including ESC1 template abuse, ESC8 machine-certificate issuance, NTLM relay and suspicious PKINIT
- [ ] **8.3 Hunt for certificates issued to the wrong identity**
  A weekly hunt compares requester and subject/SAN on issued authentication certificates, and every mismatch has an explanation

Phase 9 Troubleshooting, incident response and rollback about Ongoing

- [ ] **9.1 Triage enrollment and logon failures after hardening**
  First-line runbooks map each symptom to the phase that caused it: enrollment denied (templates/ACLs), RPC errors (ESC11 flag), HTTP 401 or 403 on certsrv/CES (Extended Protection, SSL, NTLM), logon failures (strong mapping)
- [ ] **9.2 Roll back one change at a time**
  Every change in phases 3–6 has a recorded reverse step, and the team knows which reversals are acceptable (template republish, EPA from Required to Accept) and which are not (re-enabling ESC6 or the RPC flag on a CA)
- [ ] **9.3 Respond to suspected certificate abuse**
  The incident runbook covers finding the issued certificates, revoking them, publishing a new CRL, handling active Kerberos tickets and closing the misconfiguration that was used
- [ ] **9.4 If the CA key itself is compromised: rebuild trust**
  A decision tree exists for CA key compromise: new CA hierarchy, removal of the old CA from NTAuth and trusted roots, and reissue of all certificates

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/adcs-hardening-tier0.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.